Informe M0 — Arranque y modelo de amenazas

Proyecto SBD 2026-27 · Plataforma de videojuegos online · Óscar Fernandez Andujar y Víctor Castro Quesada

1. Resumen

En este primer hito hemos formado el grupo y elegido como caso de negocio una plataforma de videojuegos online, cuyos datos sensibles principales son las cuentas, las compras in-game, los chats y los menores de edad. Hemos diseñado el modelo entidad-relación y creado el esquema en MySQL (11 tablas), hemos levantado el entorno con Docker Compose y lo hemos cargado con 1.095 filas de datos sintéticos. Después hemos clasificado los datos por nivel de sensibilidad y elaborado un modelo de amenazas inicial con 17 amenazas, que nos marca las prioridades para los siguientes hitos.

2. Reparto de trabajo

Miembro	Tareas	Commits principales
Óscar	Clasificación de datos por sensibilidad y modelo de amenazas (Informe)	Commit de los informes
Víctor	Diagrama E-R, esquema SQL, docker-compose.yml y script de datos (Faker)	Estructura inicial del proyecto; Esquema SQL, docker-compose y script de datos

3. Desarrollo

3.1 Formación del grupo y caso de negocio

El grupo lo formamos Óscar y Víctor. Elegimos el caso 4 del enunciado, una plataforma de videojuegos online, porque reúne datos de varios tipos: personales (cuentas), financieros (métodos de pago y compras), de comunicaciones (chats) y de menores de edad. Los perfiles de usuario previstos son Jugador, Creador, Distribuidor, Moderador, Administrador y DevOps, por encima del mínimo de 4 que pide el enunciado.

3.2 Modelo entidad-relación y esquema SQL

Figura E-R. Modelo entidad-relación conceptual: 9 entidades y sus relaciones con las cardinalidades.

El esquema tiene 11 tablas, por encima del mínimo de 8: `rol`, `empresa`, `categoria`, `cuenta`, `juego`, `biblioteca`, `metodo_pago`, `objeto_ingame`, `inventario`, `compra` y `mensaje`. Las decisiones principales fueron estas:

- Las relaciones N:M se resuelven con tablas propias, con clave primaria compuesta: `biblioteca` (cuenta–juego) e `inventario` (cuenta–objeto in-game).
- `juego` referencia dos veces a `empresa`, una como desarrollador y otra como distribuidor.
- `compra` registra la compra de un juego o de un objeto in-game, nunca de ambos, y un CHECK lo obliga.
- `mensaje` enlaza tres veces con `cuenta` (emisor, receptor y moderador opcional) y un CHECK impide escribirse a uno mismo.
- La integridad se refuerza con claves foráneas `ON DELETE RESTRICT`, restricciones `UNIQUE` (nick, email, número de factura, clave de activación) y CHECK en precios, horas, cantidades y clasificación de edad (3, 7, 12, 16 o 18).
- `cuenta` indica el perfil con `id_rol` y, para creadores y distribuidores, la empresa con `id_empresa` (opcional).

3.3 Entorno con Docker Compose y datos sintéticos

El entorno se levanta desde cero con `docker compose up` siguiendo el README. Usa MySQL 8.4 (imagen mysql:8, versión 8.4.11). Las credenciales están en un fichero `.env` que no se sube al repositorio, y se incluye un `.env.example`. Los datos se guardan en un volumen persistente (mysql_data) y docker compose down -v lo borra para probar desde cero.

Los datos se generan con un script en Python con la librería Faker (db/seed_datos.py). No se usa ningún dato real. Para que los datos sean coherentes aplicamos reglas como que un menor no tiene en su biblioteca juegos con clasificación superior a su edad y que el moderador de un mensaje eliminado es una cuenta con rol Moderador o Administrador.

Tabla	Filas

rol	6
empresa	15
categoria	10
cuenta	120
juego	40
biblioteca	157
metodo_pago	117
objeto_ingame	100
inventario	70
compra	300
mensaje	160
Total	**1.095**

3.4 Clasificación de los datos por nivel de sensibilidad

Hemos clasificado cada columna en los cuatro niveles vistos en clase: **P** público, **I** interno, **C** confidencial y **R** restringido. El criterio es el daño que causaría su divulgación a los jugadores (sobre todo a los menores), a la empresa y a nivel legal (RGPD, LOPDGDD y PCI DSS). Cada tabla toma el nivel más alto de sus columnas.

Nivel	Criterio	Tratamiento mínimo
P	Información de escaparate, sin daño si se conoce	Solo escritura para roles autorizados
I	Datos de funcionamiento, de impacto bajo	Acceso solo para usuarios autenticados y según su rol
C	Datos personales o de negocio cuya filtración causa daño y puede obligar a notificar una brecha	Acceso por vistas, mínimo privilegio y enmascaramiento
R	Datos cuya filtración causa un daño grave o difícil de revertir: fraude, toma de cuentas, intimidad de menores	Cifrado o hash, acceso nominal y auditoría

Tabla	Columnas	Nivel	Justificación
`cuenta`	`password_hash`	R	Permite ataques offline y toma de cuentas
`cuenta`	`email`, `telefono`, `nombre`, `apellidos`, `fecha_nacimiento`, `ip_registro`	C	Datos personales. La fecha determina si el titular es menor y la IP también es dato personal
`cuenta`	`nick`	P	Visible para otros jugadores por diseño
`cuenta`	resto	I	Datos de gestión, con integridad crítica (permisos y estado)
`metodo_pago`	`numero`, `caducidad`	R	Datos de tarjeta o IBAN (PCI DSS) que permiten fraude directo
`metodo_pago`	`titular`, `direccion_facturacion`	C	Datos personales y financieros
`compra`	`importe`, `numero_factura`, `ip_origen`	C	Historial de consumo, documentación contable e IP
`mensaje`	`texto`	R	Secreto de las comunicaciones, con posibles chats de menores
`mensaje`	`id_emisor`, `id_receptor`, `fecha`	C	Revelan con quién se comunica cada usuario
`biblioteca`	`clave_activacion`	R	Código canjeable: su filtración supone pérdida económica y reventa
`empresa`	`nombre`, `tipo`, `pais`	P	Información comercial de escaparate
`juego`, `categoria`, `objeto_ingame`	todas	P	Catálogo público, con integridad crítica en `precio` y `clasificacion_edad`
`inventario`, `rol`	todas	I	El inventario tiene valor virtual y `rol` revela el modelo de permisos

Las columnas no listadas son de nivel I. Por tabla, el resultado es: R para `cuenta`, `metodo_pago`, `mensaje` y `biblioteca`; C para `compra`; I para `empresa`, `inventario` y `rol`; y P para `juego`, `categoria` y `objeto_ingame`.

Al revisar el esquema detectamos varios puntos que condicionan los hitos siguientes:

- Los menores solo se identifican por `fecha_nacimiento`, sin registro de consentimiento de un tutor, así que el control de edad depende de datos declarados y de la aplicación.
- `metodo_pago.numero` admite 255 caracteres, suficiente para texto cifrado, pero no obliga a guardarlo así. No se almacena CVV.
- `cuenta` agrupa jugadores, moderadores y personal de empresas, diferenciados solo por `id_rol`: modificar ese campo equivale a escalar privilegios.
- `ON DELETE RESTRICT` y el borrado lógico de `mensaje` complican el derecho de supresión del RGPD, y `telefono` y `apellidos` obligatorios cuestionan la minimización.
- No existe tabla de auditoría, así que los accesos a datos R no quedan registrados.

3.5 Modelo de amenazas inicial

Seguimos el enfoque de la Unidad 1. Para cada activo identificamos la amenaza, su punto débil y el tipo de incidente (acceso no autorizado, descubrimiento de información, modificación no autorizada, invasión de la privacidad o denegación de servicio), lo asociamos a la dimensión CIA y calculamos el riesgo como probabilidad × impacto, ambos de 1 a 5. Una amenaza es pasiva si solo observa o lee información, y activa si modifica datos, ataca la aplicación o interrumpe el servicio. El tratamiento es evitar, mitigar, transferir o aceptar, con el hito en que se aplicará.

En probabilidad, 1 es muy baja y 5 muy alta. En impacto, 1 es insignificante, 3 una pérdida económica o reputacional acotada y 5 fraude financiero, daño a menores o sanción severa. Niveles de riesgo: 1–4 bajo, 5–9 medio, 10–14 alto y 15–25 crítico.

Ejemplo de cálculo (T01, inyección SQL). La probabilidad es 4 porque la inyección SQL es de los ataques más comunes contra aplicaciones web y la nuestra tendrá formularios que reciben texto del usuario. El impacto es 5 porque la base de datos guarda datos de pago y de menores. El riesgo es 4 × 5 = 20, que es crítico (15–25), y lo tratamos mitigándolo en el M3 con consultas parametrizadas y validación de entradas.

ID	Activo	Tablas	Nivel	Dimensión clave
A1	Credenciales	`cuenta` (hash)	R	C
A2	Datos de pago	`metodo_pago`	R	C, I
A3	Datos personales y de menores	`cuenta`	C / R	C
A4	Mensajes privados	`mensaje`	R	C, I
A5	Compras y facturas	`compra`	C	I, C
A6	Biblioteca y claves de activación	`biblioteca`	R	C, I
A7	Inventario y objetos in-game	`inventario`, `objeto_ingame`	I / P	I
A8	Catálogo (precio y edad mínima)	`juego`	P	I
A9	Infraestructura	MySQL, Docker, aplicación y `.env`	—	A, C

ID	Activo	Amenaza	Punto débil	Incidente	CIA	P	I	R	Tratamiento	Tipo
T01	A1–A6	Inyección SQL para volcar o alterar tablas	Consultas por concatenación y entradas sin validar	Acceso no autorizado	C, I	4	5	**20**	Mitigar · M3	Activa
T02	A9	Acceso al servidor por configuración por defecto (root remoto, cuentas anónimas, puerto expuesto)	MySQL sin bastionar	Acceso no autorizado	C, I, A	4	4	**16**	Mitigar · M2	Activa
T03	A2	Exfiltración de datos de pago en una brecha	`numero` y `caducidad` sin cifrar	Descubrimiento de información	C	3	5	**15**	Mitigar · M3; transferir a	Pasiva

									pasarela de pago en producción	
T04	A1–A6	Privilegios excesivos: la app conecta como root o los roles leen tablas directamente	Sin RBAC ni vistas de seguridad	Acceso no autorizado	C, I	3	5	**15**	Mitigar · M1–M2	Activa
T05	A3	Escalada de privilegios: un jugador cambia su `id_rol` o se hace pasar por moderador	`id_rol` editable y permisos solo en la aplicación	Modificación no autorizada	I, C	3	5	**15**	Mitigar · M2–M3	Activa
T06	A1, A6, A7	Toma de cuentas por credential stuffing o fuerza bruta	Sin límite de intentos ni política de contraseñas	Acceso no autorizado	C	4	3	**12**	Mitigar · M3	Activa
T07	A5, A8	Alteración de importes y precios para pagar menos	Escritura sin control sobre `precio` e `importe`	Modificación no autorizada	I	3	4	**12**	Mitigar · M1–M2	Activa
T08	A5–A7	Condiciones de carrera: doble canje de clave, compra duplicada, inventario inconsistente	Operaciones críticas sin transacción ni aislamiento adecuado	Modificación no autorizada	I	3	4	**12**	Mitigar · M1	Activa
T09	A3, A8	Elusión del control de edad: fecha falsa o cambio de `clasificacion_edad`	Edad solo declarada, sin verificación ni tutor	Modificación no autorizada	I	3	4	**12**	Mitigar · M1–M3	Activa
T10	A3, A4	Exposición de datos de menores (identidad, fecha de nacimiento, chats)	Datos de menores sin protección reforzada	Invasión de la privacidad	C	2	5	**10**	Mitigar · M1–M3	Pasiva
T11	A3, A4	Abuso interno: moderador, soporte o DevOps lee mensajes o datos fuera de su función	Acceso amplio y sin registro de accesos	Invasión de la privacidad	C	3	4	**12**	Mitigar · M2	Pasiva
T12	A1–A8	Modificación de datos sensibles sin dejar rastro	Sin tabla de auditoría ni registro de accesos	Modificación no autorizada	I	4	3	**12**	Mitigar · M2–M4	Activa
T13	A9	Credenciales de la BD en el código, el repositorio o la imagen Docker	Secretos fuera de `.env` o `.env` versionado	Descubrimiento de información	C	2	5	**10**	Evitar · M3	Pasiva
T14	A9	Pérdida de datos por DROP, ransomware o pérdida del contenedor	Sin política de backups ni pruebas de restauración	Denegación de servicio	A	2	5	**10**	Mitigar · M4	Activa
T15	A9	Indisponibilidad por agotamiento de conexiones o consultas costosas en un lanzamiento	Sin límites de conexiones por usuario	Denegación de servicio	A	4	3	**12**	Mitigar · M2–M3	Activa
T16	A3, A5	Incumplimiento del RGPD: no poder suprimir datos y recoger datos innecesarios	`ON DELETE RESTRICT`, borrado lógico y campos obligatorios	Invasión de la privacidad	C	3	4	**12**	Mitigar · M3–M4	Pasiva
T17	A9	Interceptación del tráfico app–BD o lectura de ficheros y backups	Sin TLS ni cifrado en reposo	Descubrimiento de información	C	2	4	**8**	Mitigar · M3–M4	Pasiva

Matriz de riesgo (probabilidad × impacto):

P \ I	1	2	3	4	5
5					
4			T06, T12, T15	T02	T01
3				T07, T08, T09, T11, T16	T03, T04, T05
2				T17	T10, T13, T14
1					

Por dimensión, la confidencialidad es la más expuesta (11 amenazas), seguida de la integridad (8) y la disponibilidad (3); una amenaza puede afectar a más de una. Hay cinco amenazas críticas (T01–T05), todas relacionadas con el acceso a cuentas y datos de pago, y por eso orientan el orden de trabajo de los próximos hitos.

4. Evidencias

docker compose up -d y docker compose ps: el contenedor sbd_mysql (imagen mysql:8) arranca y publica el puerto 3306.

SHOW TABLES en la base tienda_juegos: las 11 tablas del esquema.

SELECT COUNT(*) FROM cuenta en la base tienda_juegos: las 120 cuentas cargadas por el script de datos.

Prueba de integridad: insertar una compra con juego y objeto a la vez falla con el error 3819 (chk_compra_un_producto).

5. Problemas encontrados y cómo se resolvieron

1. El diseño pasó de 14 a 11 tablas. El borrador tenía 14, pero quitamos plataforma y juego_plataforma porque no las usaba ninguna otra tabla y solo guardaban datos públicos. Dejamos objeto_ingame, inventario y mensaje porque tienen datos más interesantes para la parte de seguridad. Son más de las 8 que pide el enunciado.
2. Campos mal definidos en el diagrama. fecha_nacimiento, clasificacion_edad, importe y fecha admitían NULL, y así se podía saltar la regla de menores. Los pusimos NOT NULL. Solo admiten NULL id_empresa en cuenta, id_juego e id_objeto en compra e id_moderador en mensaje. Además metodo_pago.numero estaba como int y un número de tarjeta o IBAN no cabe en un entero (pierde los ceros del principio y luego lo ciframos, que ocupa más). Lo cambiamos a VARCHAR(255).
3. Quitamos DROP DATABASE y COLLATE del script. El DROP lo teníamos para repetir las pruebas, pero borra toda la base de datos y en una asignatura de seguridad es un riesgo si se ejecuta donde no toca. Para empezar de cero usamos docker compose down -v y up -d, que es la prueba que pide el enunciado. El COLLATE lo quitamos porque probamos en MySQL 8 y sin él las 11 tablas quedan igual con utf8mb4_0900_ai_ci, que es la de por defecto. Así el script también vale en MariaDB.
4. Error de usuario de GitHub al hacer push. Al subir el repo, Git dio el error «remote: Repository not found». Pasaba porque el remoto apuntaba a un usuario de GitHub equivocado (H0llowBlaze en vez de Vittox). Lo arreglamos con git remote set-url origin https://github.com/Vittox/sbd-videojuegos.git y, como el primer commit se hizo con una identidad de Git de prueba, lo rehicimos con git commit --amend --reset-author. Después el push funcionó. También revisamos que .env está en el .gitignore para no subir contraseñas.

6. Riesgos pendientes y conclusión

Al cierre del M0 el sistema todavía no tiene medidas de seguridad aplicadas: solo tenemos el diseño, el entorno y el análisis de riesgos. Lo que sigue sin proteger y el hito en que se aborda es lo siguiente:

Hito	Amenazas que se tratan
M1 (vistas, transacciones, aislamiento)	T04, T07, T08, T09, T10
M2 (bastionado y RBAC)	T02, T04, T05, T11, T15
M3 (aplicación, SQLi y cifrado)	T01, T03, T06, T13, T16, T17
M4 (backups y comparativa)	T12, T14

Conclusión. El M0 nos deja una base funcional y un mapa claro de prioridades. Las amenazas críticas se concentran en el acceso a cuentas y datos de pago, y por eso empezaremos reduciendo la superficie de acceso con vistas y roles (M1 y M2) antes de abordar la aplicación y el cifrado (M3).

7. Declaración de uso de IA

Nuestro uso de IA ha sido en un enfoque estructural de datos ayudándonos a como repartir y decidir cuáles eran los datos más importantes en los esquemas en base a nuestro criterio, también los archivos faker de relleno de datos los cuales han sido muy tediosos con muchos errores y pruebas y por pura optimización nos hemos apoyado a en pulir el código y informes como Readme ya que la claridad con la cual genera los informes markdown nos facilita a que se vea el proyecto mejor en GitHub.